# EXPEDIENTE DE NOTIFICACIÓN DE INCIDENTE DE CIBERSEGURIDAD

## FORMULARIO OFICIAL CSIRT NACIONAL / AGENCIA NACIONAL DE CIBERSEGURIDAD (ANCI)

### Conforme a las obligaciones de la Ley Marco de Ciberseguridad (Ley Nº 21.663 - Chile)

**ESTADO DEL EXPEDIENTE:** `NOTIFICACIÓN PRELIMINAR (PLAZO 3 HORAS)`
**CÓDIGO DE INCIDENTE GMA-DEV:** `INC-SEC-20261030-9082`
**NIVEL DE SEVERIDAD:** `CRÍTICO (P1)`
**FECHA Y HORA DE EMISIÓN:** `2026-10-30 21:07:20 UTC` (`18:07:20 CLT`)

## 1. IDENTIFICACIÓN DE LA ORGANIZACIÓN Y RESPONSABLE TÉCNICO

| Campo | Detalle Declarado |
|---|---|
| **Nombre de la Entidad / Operador:** | Empresa de Servicios Web SpA |
| **RUT de la Entidad:** | `76.xxx.xxx-x` |
| **Sector / Tipo de Entidad:** | Operador de Importancia Vital (OIV) / Servicio Esencial |
| **Responsable de Ciberseguridad / Notificante:** | Eugenio Cortés (DevOps & Security Lead) |
| **Correo Electrónico de Contacto:** | `seguridad@empresa.cl` / `ops@empresa.cl` |
| **Teléfono de Emergencia 24/7:** | `+56 9 xxxx xxxx` |

## 2. CLASIFICACIÓN Y TAXONOMÍA DEL INCIDENTE (TAXONOMÍA CSIRT)

- **Categoría Principal:** `Acceso No Autorizado / Intrusión Web`
- **Subcategoría:** `Inyección de Código (SQL Injection / Parameter Tampering)`
- **Vector de Ataque:** Petición HTTP maliciosa dirigida al endpoint de autenticación para provocar un bypass de control de acceso administrativo.
- **Impacto Operacional:** `Medio` (Contenido antes de comprometer la persistencia de datos).
- **Impacto en Información:** `Bajo` (No se detectó exfiltración masiva de registros personales).

## 3. LÍNEA DE TIEMPO FORENSE (TIMELINE)

| Marca Temporal (UTC) | Hora Local Chile (CLT) | Hito / Evento Forense |
|---|---|---|
| `2026-10-30 21:05:12Z` | `18:05:12 CLT` | Primer intento de payload malicioso detectado por WAF perimetral. |
| `2026-10-30 21:05:40Z` | `18:05:40 CLT` | Disparo de anomalía correlacionada en GMA-DEV con HTTP 403 Forbidden. |

| | | |
|---|---|---|
| `2026-10-30 21:06:00Z` | `18:06:00 CLT` | Alerta enviada automáticamente a Discord/Telegram con IP enmascarada y puntero seguro. |
| `2026-10-30 21:06:15Z` | `18:06:15 CLT` | Bloqueo perimetral automático de la IP atacante en Cloudflare / Firewall perimetral. |
| `2026-10-30 21:07:20Z` | `18:07:20 CLT` | Generación y sellado criptográfico del presente expediente ANCI. |

---

## 4. EVIDENCIA TÉCNICA E INDICADORES DE COMPROMISO (IOCs)

> ***NOTA DE CUMPLIMIENTO LEGAL:*** *Los siguientes datos provienen de la bóveda inmutable de auditoría local de GMA-DEV y han sido desencriptados exclusivamente para esta notificación oficial conforme a la Ley 21.663.*

### A. Datos del Atacante

- **Dirección IP de Origen:** `185.220.101.5`
- **País / Geolocalización ASN:** Alemania (Nodo de salida Tor / Proxy Anonimizador conocido).
- **Puerto de Origen:** `44322`
- **User-Agent Empleado:** `sqlmap/1.8#stable (https://sqlmap.org)`

### B. Activos Afectados

- **Endpoint / URL:** `https://api.tuempresa.cl/v1/auth/login`
- **Parámetro Vulnerable atacado:** `token` / `password`
- **Fragmento de Payload Recuperado:**



### C. Integridad y Validez Probatoria

- **Firma Criptográfica SHA-256 de Evidencia:** `4a7b1c8f902e4d56789abcde0123456789abcdef0123456789abcdef01234567`
- **Grabación de Comportamiento en Microsoft Clarity:** https://clarity.ms/projects/view/w13cujuo4o/impressions/demo-attack-session

---

## 5. MEDIDAS DE MITIGACIÓN Y CONTENCIÓN ADOPTADAS

1. **Bloqueo Inmediato de Tráfico:** Regla dinámica aplicada en el Firewall de Borde bloqueando la subred `185.220.101.0/24`.
2. **Sanitización de Consultas:** Parche de seguridad desplegado en el microservicio de autenticación implementando sentencias preparadas (*Prepared Statements*) en ORM.
3. **Invalidación de Sesiones:** Forzado de revocación de tokens JWT activos emitidos en los últimos 30 minutos como medida preventiva.

---

## 6. DECLARACIÓN JURADA DE VERACIDAD

El presente informe ha sido preparado por el equipo de operaciones e ingeniería conforme al **Artículo 7 y Artículo 14 de la Ley Nº 21.663**, dejando constancia de que las marcas temporales y datos técnicos expuestos son copias fieles de los registros generados por los sistemas de telemetría inmutables.

**Firma Responsable Técnico:**

*Eugenio Cortés — DevOps & SecOps Engineer*

*Empresa de Servicios Web SpA*